

Propuesta: análisis de tráfico de red en entornos IoT para detección de ataques

Descripción:

Una de las principales tareas de la monitorización de sistemas de Internet de la Cosas es la **detección de anomalías**. Por anomalías entendemos conjuntos de paquetes de red cuyo **comportamiento es inesperado**. Estas anomalías pueden **deberse en primera instancia a fallos en los componentes del sistema IoT**. Pero también **pueden estar relacionados con ataques contra la seguridad de los sistemas**. *las anomalías no son siempre por ataques, pueden ser tb por fallos*

En este segundo caso, la detección de anomalías tiene lugar en el contexto de la detección de intrusiones. Este es un enfoque basado en el **análisis del comportamiento normal de la red o del sistema para identificar desviaciones** que puedan indicar actividades maliciosas. A diferencia de los métodos basados en firmas, que detectan amenazas conocidas, la detección de anomalías permite identificar ataques novedosos o desconocidos, como intentos de intrusión, malware o movimientos laterales dentro de una red. Este enfoque **emplea técnicas de aprendizaje automático, análisis estadístico y correlación de eventos para establecer patrones de tráfico** legítimo y detectar irregularidades, como un aumento inusual de tráfico, accesos a recursos restringidos o cambios en los hábitos de uso. Aunque es una técnica poderosa, su principal desafío radica en minimizar los falsos positivos, asegurando que las anomalías detectadas realmente representen una amenaza y no solo variaciones legítimas en el comportamiento de los usuarios o sistemas.

Generalmente las herramientas de detección de intrusiones suelen utilizar una versión ampliada el **protocolo NetFlow** para agrupar paquetes de red en conversaciones y calcular una serie de **valores estadísticos** con los que intentar determinar si dicha conversación es tráfico de red legítimo o por el contrario es una intrusión. **NetFlow es un estándar desarrollado por Cisco para la recolección, análisis y monitoreo del tráfico de red**. Permite **capturar información detallada sobre los flujos de datos que atraviesan un dispositivo de red, como la dirección IP de origen y destino, el puerto, el protocolo, la cantidad de paquetes y bytes, entre otros**. Esta información es utilizada para la gestión del ancho de banda, la detección de anomalías, la seguridad y la planificación de la red. NetFlow ha evolucionado en varias versiones y ha dado lugar a estándares abiertos como IPFIX, utilizados por distintos fabricantes para mejorar la interoperabilidad en la monitorización del tráfico de red.

Para entrenar estas herramientas se suelen utilizar conjuntos de datos ya preparados dónde cada registro es una conversación entre dos dispositivos (dos direcciones IP) en la red que utilizan el mismo puerto (TCP o UDP). Y cuentan con dos etiquetas clasificadores: si es o no tráfico anómalo, y el tipo de ataque al que se corresponde en caso de ser una anomalía.

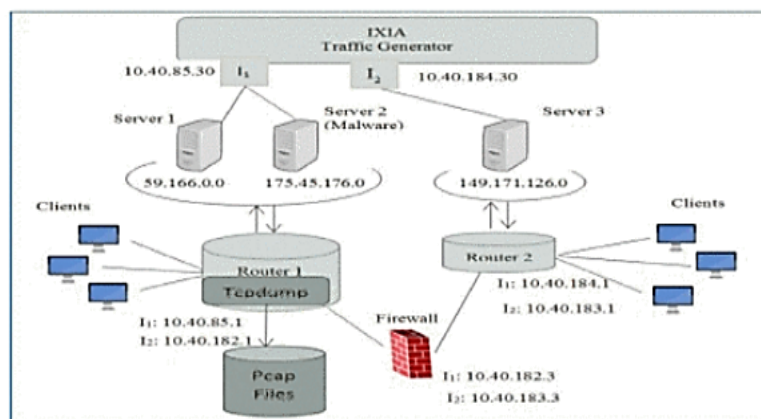
El principal objetivo de esta visualización sería analizar dichas conversaciones para intentar detectar las características comunes entre los distintos tipos de ataques. Por ejemplo, un ataque basado en denegación de servicio se caracterizaría por un gran

volumen de paquetes todos hacia el objetivo del ataque y gran número de conversaciones. Mientras que los escaneos de sistemas suelen utilizar el protocolo ICMP.

Fuentes de datos:

La principal fuente de datos de esta visualización sería el conjunto de datos UNSW-NB15 (<https://research.unsw.edu.au/projects/unsw-nb15-dataset>). Este conjunto de datos ha sido generado en un laboratorio virtual utilizando el programa IXIA representando un sistema IoT. Para capturar el tráfico de red en forma de paquetes, se usó la herramienta tcpdump durante 16 horas el 22 de enero de 2015 y de 15 horas el 17 de febrero de 2015 para **capturar 100 GB**. Cada archivo PCAP, conteniendo el tráfico capturado, se dividió en 1000 MB utilizando la herramienta tcpdump. A partir de los ficheros PCAP se han extraído las características utilizando las herramientas Argus y Bro-Ids.

La arquitectura de red creada fue la siguiente:



De manera que los **datos tabulados en formato CSV con los que podemos trabajar se encuentran** en la **carpeta denominada CSV** en la zona de descarga. Además, encontraremos la descripción de los campos de los conjuntos de datos, un listado de todos los eventos ocurridos durante la captura de los datos y cuatro CSVs con los datos ya procesados y etiquetados de la red.

Es un **dataset de grandes dimensiones**, con 49 características y cerca de 100GB de datos.

En estos datos encontramos nueve ataques distintos:

- **Fuzzers**, ataques basados en intentar que una red falle generando paquetes de red con datos aleatorios.
- **Analysis**, agrupa diferentes tipos de ataques basados en escaneo de puertos, spam de paquetes e intentos de modificación de páginas html.
- **Backdoors**, basados en saltarnos los mecanismos de seguridad de la red de manera silenciosa para acceder a los datos del sistema.
- **DoS** (denegación de servicio), es un ataque coordinado con el fin de agotar los recursos de algún dispositivo de la red mediante una inundación de peticiones.

- **Exploits**, que es un programa diseñado para explotar una vulnerabilidad conocida de un sistema o de un componente de la red, generalmente con el fin de acceder o obtener unos privilegios.
- **Generic**, ataque centrado en los algoritmos de cifrado de bloques basado en el conocimiento sobre la estructura el bloque.
- **Reconnaissance**, ataques orientados a la obtención de información utilizando la herramienta Strikes.
- **Shellcode**, un fragmento de código malicioso insertado en un programa orientado a explotar una vulnerabilidad.
- **Worms**, son un tipo de malware autónomo que se autoreplica y se intenta expandir hacia otros sistemas.